LABORATUVAR 6 · ROBOWAAM ADVANCED · Tel Ark Eklemeli İmalat

6 CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad **Muhammet Baykara** | Grup **Gece 4/B** | Tarih **24/10/2026**

Senaryo: Saat **10:15**. RoboWAAM'ın WAAMCtrl servis hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. Kontrol elektroniği/robot programı ve proses parametreleri (akım, tel hızı, O_2 eşiği, alarm limitleri) değişmiş olabilir; **muhafaza kapı kilidi / O_2 interlock / acil dur parametreleri henüz doğrulanmadı.** Makine, sabahtan beri süren çok saatlik bir build'in ortasında çalışıyor. Vardiya sorumlusu sizsiniz. (Lab 3 S1/S2 senaryolarının gerçekleşmiş hali.)

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

10:15	+15 dk	+2 saat	+24 saat	+72 saat	+14 gün
1	2	3	4	5	6
Tespit karar noktası	**İlk 3 eylem** güvenli durum	**Doğrulama** emniyet + kanıt	**CRA erken uyarı** ilk bilgi	**CRA bildirimi** kök neden · etki	**Son rapor** kanıt paketi

Görev — zaman çizgisini doldurun

1 10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?

Aynı anda iki hat açılır: **emniyet** ve **OT-güvenlik**. Aramalar sırasıyla:

Sıra	Kim	Neden / ne istenir
1	**Tesis emniyet (EHS) sorumlusu + bakım/kontrol mühendisi**	Emniyet fonksiyonlarının doğrulanması; muhafazaya giriş yetkisi onlardadır
2	**OT/IT güvenlik – olay müdahale lideri**	Ağ izolasyonu, log toplama, adli kanıt yöntemi
3	**WAAM3D destek / ürün güvenliği (PSIRT)** [V]	Servis hesabı üreticiye mi ait? Bilinen olay? Konfigürasyon referansı (golden config) ve CRA bildirim bilgileri
4	Üretim müdürü / olay yöneticisi; hukuk-uyum	Üretim kararı, yasal bildirim sorumlusunun belirlenmesi

İlk üç eylem (ilk 15 dakika):

- **1 · Güvenli duruma al, kimseyi içeri alma.** Muhafaza erişimini yasakla (işaretle/kilitle); deposition'ı **kontrollü** durdur (katman sonu veya güvenli kesme noktası; durum şüpheliyse acil dur). Inert atmosfer ve duman tahliyesi **çalışmaya devam eder**; O_2 doğrulanmadan kapı açılmaz (Lab 1 güvenli durum tanımı).
- **2 · Uzak yolu kes, sunucuyu kapatma.** Uzak erişimi ağ düzeyinde kes (VPN/internet çıkışı, güvenlik duvarı kuralı); WAAMCtrl sunucusu, PLC ve robot kontrolörü **açık ve olduğu gibi kalır** — güç kesmek bellek içi kanıtı siler.
- **3 · Olay günlüğünü başlat.** Saat, kim neyi gördü, hangi ekran; ekran ve durum ışıklarının fotoğrafı. Hiçbir parametreyi "eski haline" çevirme, hiçbir reset/yeniden başlatma yapma.

2 İlk 2 saat: Emniyet zinciri güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

Kural: doğrulanana kadar emniyet zinciri "güvenli değil" sayılır. Makine güvenli durumdayken ve muhafaza boşken, yetkili kişi (EHS + kontrol mühendisi) tarafından:

Doğrulama	Yöntem	Geçme ölçütü
Yapılandırma bütünlüğü	Emniyet yapılandırması/yazılım imzası-CRC'sini son validasyon kaydıyla karşılaştır; mod anahtarı konumu ve değişiklik günlüğü	İmza/CRC birebir aynı; kayıtsız değişiklik yok
SF-1 acil dur	Fonksiyon testi + durma süresi ölçümü	Önceki ölçümden kötü değil
SF-2 kapı interlock	Kapı açma/kilit sırası testi; kapı açıkken hareket/ark başlatma denemesi	Başlamaz, kilit mantığı doğru
SF-3 O_2 interlock	Bağımsız/kalibre O_2 ölçer ile çapraz kontrol; eşik değeri ve alarm kaydı	Eşik referans değerde; sensör okuması tutarlı
SF-6 ark-enable ve SF-5 hız	Kapı açıkken enable denemesi; manuel mod hız limiti	Reddedilir; limit korunur
Proses parametreleri	WAAMCtrl parametre/alarm limitlerini golden config ile diff	Fark yok veya farklar listelenmiş

Korunan kanıt (uçucu olandan kalıcıya): WAAMCtrl sunucu ve PLC/robot kontrolörü *canlı hali* (kapatılmadan imaj/snapshot) → WAAMCtrl denetim ve veri tabanı kayıtları → uzak erişim/VPN, güvenlik duvarı ve kimlik doğrulama logları → parametre ve program yedekleri (olay öncesi/sonrası) → emniyet yapılandırması imzası → CCTV kaydı → proses (SPC) ve build kayıtları → vardiya/olay günlüğü. Hepsi **salt-okunur kopya + SHA-256 özet + saklama zinciri (chain of custody)** ile; saatler NTP ile senkron doğrulanır.

Kapatılan hesap: o servis hesabı ve **aynı kimlik bilgisini paylaşan tüm hesaplar** devre dışı bırakılır, silinmez (iz kaybolmasın); açık oturumlar sonlandırılır; parola/anahtar/VPN sertifikaları döndürülür; üretici ve müşteri servis hesapları ayrıca gözden geçirilir. Ortak servis hesabı olması (Lab 4'te "kişisel hesap" ilkesi) kök neden adayıdır [V].

3 24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?

Önce **eşik kararı**: olay "aktif olarak istismar edilen zafiyet" veya "ciddi olay" sayılıyor mu? Saat 2'deki doğrulama sonucu karara bağlanır; şüphe varsa erken uyarı **yapılır**, kanıt gelince güncellenir. Yasal bildirimi ürün üreticisi (WAAM3D) yapar; vardiya sorumlusu olarak biz bilgiyi **hazır** eder, üreticiye ve kuruma iletiriz [K]. Erken uyarıda şunlar hazır olmalı:

Bilgi	RoboWAAM için içerik
Ürün kimliği	RoboWAAM® Advanced, seri no; WAAMCtrl, kontrol elektroniği ve robot yazılım sürümleri
Olayın niteliği	Servis hesabıyla 03:00'te yetkisiz/tanınmayan konumdan oturum; olası kötü niyetli eylem [V]
Zaman çizelgesi	İlk giriş, tespit (10:15), müdahale saatleri; log kaynağı
Etkilenen yer / ülke	Tesis ve ülke; diğer kurulu sistemlerin etkilenme olasılığı (aynı hesap/yazılım)
Emniyet etkisi	Emniyet fonksiyonlarının durumu: doğrulandı / doğrulanıyor / bozulmuş (bilinmiyorsa açıkça "bilinmiyor")
Alınan önlemler	Güvenli duruma alma, uzak yolun kesilmesi, hesap kapatma
İletişim	Sorumlu kişi, 7/24 ulaşılabilir kanal

4 72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?

Rol	72 saat içinde yaptığı
Vardiya sorumlusu / operatör	Olay günlüğü, ilk gözlemler, makine durumu; kanıt zincirini korur; sahada geçici önlemleri uygular
OT/IT güvenlik	Adli analiz: giriş vektörü (çalıntı/paylaşılan parola, MFA yokluğu, açık uzak erişim), yanal hareket, değişen yapılandırmalar; IoC listesi; **kök neden** hipotezi
EHS + kontrol mühendisi	**Etki:** emniyet fonksiyonu etkilendi mi (imza + fonksiyon testi sonucu); build'deki parçalar için kalite/emniyet etkisi (şüpheli parametreyle üretilen katmanlar)
WAAM3D (üretici) [K]	Güncellenmiş bildirimi CSIRT/ENISA'ya iletir; zafiyet/olay değerlendirmesi, düzeltici önlem ve etkilenen diğer müşteriler
Yönetim / hukuk-uyum	Bildirim yükümlülüklerinin kapsamı (üretici CRA; işletmeci NIS2'ye tabiyse ayrı 24s/72s [K] [V]), iletişim, üretim kararı

Önlem: kalıcı çözüm paketi — ortak hesabın kaldırılması, kişisel hesap + MFA + jump server + varsayılan kapalı uzak erişim (Lab 4), emniyet bağımsızlığı gereksinimleri R-01…R-08 testi, şüpheli build parçalarının karantinası/NDT.

5 14 gün — son rapor: Hangi loglar/kayıtlar korunmuş olmalı?

Kayıt grubu	İçerik	Neden
WAAMCtrl	Denetim izi, veri tabanı, kalite günlüğü, parametre/alarm değişiklik geçmişi	Kimin neyi, ne zaman değiştirdiği
Uzak erişim	VPN/jump server, kimlik doğrulama, oturum kayıtları, güvenlik duvarı	Giriş vektörü ve kapsam
Kontrol katmanı	PLC/robot programı, emniyet yapılandırması imzaları (öncesi/sonrası), mod anahtarı kaydı	Emniyet etkisinin kanıtı
Fiziksel/proses	O_2/akış, SPC ve build kayıtları, CCTV, operatör günlüğü	Etki ve parça güvenliği
Adli kopyalar	Disk/bellek imajları, SHA-256, saklama zinciri, NTP doğrulaması	Delil değeri
Süreç	Karar günlüğü (kim, neyi, hangi saatte), bildirim kopyaları	Yasal uyum ve ders çıkarma

Not: Föy "14 gün" der; CRA'da zafiyet için nihai rapor *düzeltici önlemin mevcut olmasından 14 gün sonra*, ciddi olay için *72 saatlik bildirimden itibaren 1 ay içinde* istenir [K] — resmî metinle doğrulayın. Saklama süresi ≥ 12 ay önerilir [V].

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt. RoboWAAM'da buna ek: WAAMCtrl sunucusunu kapatıp açmak, build'i "baştan başlatmak" veya parametreleri eski değerine çevirmek de kanıtı ezer.

▤ Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.